

TianShanOS

安全页面完整操作指南

基于 main 分支当前代码的操作、验证与恢复手册

账号安全 · SSH 密钥 · 主机指纹 · HTTPS / mTLS · Config Pack

生成日期：2026-09-01

目录

1. 先看这里4

1.1 这页能做什么4

1.2 角色不要混淆4

1.3 开始前的连接条件4

1.4 先理解六个术语5

2. 个人用户快速开始5

2.1 立即处理默认密码5

root 在安全页修改密码5

2.2 创建可用于 SSH 的密钥5

2.3 部署到服务器6

2.4 正确验证连接6

2.5 正确撤销权限7

3. SSH 密钥与服务器管理7

3.1 正确的密钥生命周期7

3.2 公钥、私钥与导出7

导出公钥7

导出私钥8

3.3 “已部署主机”不是服务器事实源8

3.4 SSH 主机指纹8

首次连接8

服务器指纹变化8

指纹记录的存储风险9

3.5 导入和导出 SSH 主机配置9

导出主机配置9

导入主机配置9

4. HTTPS 与 mTLS9

4.1 先分清三种身份9

4.2 规划证书名称和用途9

4.3 生成 HTTPS 密钥10

4.4 生成并签发 CSR10

4.5 安装设备证书10

4.6 安装客户端 CA 链并验证 mTLS	10
4.7 删除全部 PKI 凭证	10
5. Config Pack	10
5.1 它的信任关系	11
5.2 当前哪些功能可用	11
5.3 导出设备证书	11
5.4 验证收到的配置包	11
5.5 不要用当前通用“应用”判断配置已生效	11
5.6 Developer 导出配置包	12
6. 安全事件与恢复	12
6.1 SSH 私钥疑似泄露	12
6.2 服务器重装或指纹变化	12
6.3 证书过期或 HTTPS 私钥泄露	12
6.4 远端撤销与本地记录不一致	13
6.5 删除凭证前的恢复入口	13
7. 故障排查	13
8. 当前必须接受的安全限制	14

这份指南面向个人用户、安全管理员和负责设备运维的工程师。它说明当前安全页面实际能做什么、不能做什么，以及每次操作后怎样确认真的生效。

重要：当前完整 WebUI 使用 HTTP。不要在公共 Wi-Fi、访客网络或其他不可信网络中输入登录密码、SSH 密码或导出私钥。优先使用隔离的管理网络，并限制谁能访问设备的 80 端口。

1. 先看这里

1.1 这页能做什么

安全页面从上到下包含六个区块：

区块	主要用途	普通个人用户是否常用
账号安全	root 修改 root/admin 密码，或重置 admin 密码	首次使用时需要
密钥管理	创建 SSH 密钥、查看公钥、按条件导出私钥、部署、撤销、删除	常用
已部署主机	查看本地保存的服务器记录，测试、导出、撤销或移除记录	常用
已知主机指纹	查看或删除 SSH 服务器身份记录	出现服务器重装、换机或安全告警时需要
HTTPS 证书	管理设备的 443 服务证书、CSR 和 mTLS 客户端 CA	高级/企业配置
Config Pack	加密、签名和分发配置包	当前不应作为通用配置生效流程使用

1.2 角色不要混淆

身份	当前作用
admin	前端路由允许进入安全页，页面会显示密钥、SSH、证书和 Config Pack 功能，但不显示“账号安全”。
root	前端显示与 admin 相同的安全功能，并额外显示“账号安全”，可设置 root/admin 密码和重置 admin。
Developer 设备	这是设备证书中的属性，不是登录账号。它决定设备是否可导出 Config Pack 和 SSH 主机配置。root 登录不会把普通设备变成 Developer 设备。

上表只描述浏览器页面的显示规则，不是后端安全边界。当前通用 `/api/v1/*` 调用入口中，写操作的登录检查被注释，API 注册项的 `requires_auth` 和 `permission` 也没有在调用时执行。除密码管理等自行校验令牌的 handler 外，不能把“页面要求登录”当成接口已完成鉴权。设备不应直接暴露给不可信网络。

1.3 开始前的连接条件

在进行任何安全操作前，请确认：

- 1 电脑和 TianshanOS 位于你控制的管理网络。
- 2 浏览器地址栏中的设备 IP 是你要管理的那台设备。
- 3 SSH 目标服务器地址、端口、用户名由服务器管理员确认。

- 部署或撤销 SSH 公钥时，目标账户当前允许密码登录；操作完成后是否继续允许密码登录由服务器安全策略决定。本指南不会建议为排障而长期打开密码登录。
- 做删除、覆盖或证书更换前，已有另一条可用的管理入口。

1.4 先理解六个术语

- NVS：设备 Flash 中保存设置和密钥数据的区域。当前构建未启用 NVS Encryption，所以不能把其中的私钥描述为“已加密静态存储”。
- TOFU：第一次连接时先信任看到的服务器身份，以后再检查是否变化。当前 WebUI 会自动完成这次首次信任。
- CSR：设备用自己的私钥生成的“证书申请单”，交给 CA 签发；CSR 本身不含私钥。
- SAN：证书中允许访问的 DNS 名称或 IP 地址。现代客户端通常按 SAN 判断访问地址是否匹配。
- CA：签发或验证证书的机构/证书。设备里的客户端 CA 与电脑浏览器里的服务器信任库不是一回事。
- mTLS：连接双方都出示证书；服务器证明“我是设备”，客户端证书证明“我是谁”。
- PEM：以 -----BEGIN ...----- 开头的文本证书、CSR 或密钥格式。
- EKU：证书声明的用途，例如服务器认证或客户端认证。
- Config Pack：TianshanOS 的 .tscfg 加密配置包格式。

2. 个人用户快速开始

2.1 立即处理默认密码

适用场景：首次登录、密码泄露、人员变更。谁可以操作：每个已登录用户可在登录后的密码提醒中修改自己的密码；安全页的账号安全区块只对 root 显示。会改变什么：更新设备本地账号密码；不会修改 SSH 服务器密码。

root 在安全页修改密码

- 以 root 登录，进入“安全”。
- 在“账号安全”中选择“设置 root 密码”或“设置 admin 密码”。
- 两次输入相同的新密码，然后提交。

界面允许 4-64 个字符。请把 4 个字符理解为技术下限，而不是安全建议；实际应使用独有的长密码。

成功后应该看到：密码设置成功提示。当前已登录会话不会因此自动退出。验证：打开无痕窗口或退出当前会话，用新密码重新登录。不要只依赖成功提示。失败处理：两次输入不一致、长度不符或令牌失效时重新输入；连续 5 次登录失败会锁定约 5 分钟。恢复：root 可把 admin 重置为默认密码 `rm01`，同时清除 admin 登录锁定。重置后应立即用新会话登录 admin 并改成独有密码。

不要把 `rm01` 留作长期密码。登录后的默认密码提醒可以被“稍后修改”关闭，系统不会替你强制完成修改。

2.2 创建可用于 SSH 的密钥

适用场景：让设备免密码连接 Linux 服务器。页面向谁显示：已登录的 admin 或 root。这是前端可见性，不代表后端已执行角色鉴权。前置条件：SSH 密钥库未达到 8 个密钥。会改变什么：在设备 NVS 中新增一对公钥/私钥；尚未改变任何服务器。

- 1 在“密钥管理”点击“生成新密钥”。
- 2 输入唯一的密钥 ID。建议包含用途，例如 `backup-server`，不要放密码或其他秘密。
- 3 选择 RSA 2048-bit（推荐）；需要更大的 RSA 密钥时可选 RSA 4096。
- 4 可填写备注和别名。
- 5 除非明确需要离线备份或迁移，否则不要勾选“允许导出私钥”。
- 6 不要把“隐藏密钥 ID”当成安全控制；当前实现仍可能返回真实 ID。
- 7 点击“生成”。

为什么不选 ECDSA：页面虽然能生成 ECDSA P-256/P-384，但当前 SSH 公钥认证流程不支持它们。HTTPS 的 ECDSA 密钥是另一套独立密钥。成功后应该看到：密钥表中出现新条目、类型为 RSA，并显示公钥、部署、撤销和删除操作。验证：点击“公钥”，确认能看到以 `ssh-rsa` 开头的公钥文本。失败处理：若提示存储已满，先按本指南的撤销顺序清理不用的密钥；若 ID 已存在，换一个 ID。恢复：尚未部署到服务器时可直接删除；一旦部署，必须先远端撤销再删除本地密钥。

2.3 部署到服务器

适用场景：把刚生成的 RSA 公钥加入远端账户。页面向谁显示：已登录的 admin 或 root；实际部署还必须持有目标服务器账户密码。这是前端可见性，不代表后端已执行角色鉴权。前置条件：服务器可达、SSH 端口正确、目标账户允许当前密码认证、设备中有对应 RSA 密钥。会改变什么：把公钥追加到远端账户的

`~/.ssh/authorized_keys`，并在设备上新增“已部署主机”和“已知主机指纹”记录。

- 1 在目标密钥行点击“部署”。
- 2 输入目标主机、用户名、端口和该远端账户的 SSH 密码。
- 3 再次确认地址与账户，然后点击“开始部署”。

当前安全边界：实现会先把密码用于 SSH 认证，再检查服务器指纹；新服务器默认会被自动信任。因此首次部署不具备“先核验主机、再发送密码”的严格保护。首次连接应在隔离网络中完成，并由管理员随后比对指纹。成功后应该看到：部署成功提示，且服务器出现在“已部署主机”。验证：不要停在部署提示。转到“已部署主机”，点击“测试”；测试会使用所选密钥连接并执行一条固定的回显命令。部分失败：公钥已经追加但密钥登录复验失败时，后端仍可能把部署记为成功。保存本地主机记录失败也不会把部署结果改成失败，因此成功提示后列表中可能没有新记录。无论哪种情况，都先从另一管理入口检查远端 `authorized_keys`；不要直接重复点击部署，因为当前部署会直接追加，可能产生重复公钥行。恢复：使用“撤销”从远端删除公钥；不要先删除本地密钥。

2.4 正确验证连接

适用场景：部署后、服务器维护后、定期巡检。页面向谁显示：已登录的 admin 或 root。这是前端可见性，不代表后端已执行角色鉴权。会改变什么：可能在首次连接时自动保存主机指纹；不会修改业务配置。

- 1 在“已部署主机”找到对应主机。
- 2 核对地址、端口、用户名和密钥 ID。
- 3 点击“测试”。

成功的含义：设备使用该密钥建立 SSH 会话，并成功执行固定回显命令。它不证明 `sudo`、其他账户或其他业务命令有权限。失败处理：先检查网络、端口、远端 SSH 服务、账户和密钥是否仍在 `authorized_keys`；若提示与

主机身份有关，立即停止并按“服务器指纹变化”流程处理。恢复：测试本身无需恢复；若测试期间错误信任了新地址，删除对应已知主机指纹并先核对真实服务器身份。

2.5 正确撤销权限

适用场景：设备丢失、私钥疑似泄露、服务器退役、人员或用途变化。页面向谁显示：已登录的 admin 或 root；实际撤销还必须持有远端账户密码。这是前端可见性，不代表后端已执行角色鉴权。前置条件：确认还有其他可用管理入口，且本地密钥尚未删除。会改变什么：删除远端 `authorized_keys` 中与该公钥匹配的所有行；成功后，从“已部署主机”发起的撤销还会删除本地主机记录。

- 1 优先从“已部署主机”点击对应主机的“撤销”。
- 2 输入服务器密码并确认“撤销并移除”。
- 3 等待页面报告删除数量。
- 4 使用另一条管理员入口检查远端 `authorized_keys`，并确认该密钥已不能登录。
- 5 检查远端 `~/.ssh/authorized_keys.bak`；当前撤销会创建这个备份，它可能仍包含旧公钥。按服务器备份策略安全处理。
- 6 确认所有目标服务器都撤销后，再删除设备本地密钥。

未找到密钥：页面会允许只移除本地记录。只有在你已经从服务器侧确认密钥确实不存在时才这样做。撤销失败：保留本地密钥和主机记录，改用服务器控制台或另一管理员账户手工删除对应公钥。恢复：误撤销后，只能在确认服务器身份的前提下重新部署；本地移除记录不能恢复远端权限。

3. SSH 密钥与服务器管理

3.1 正确的密钥生命周期

按以下顺序管理一把密钥：

- 1 创建 RSA 密钥。
- 2 必要时安全保存私钥备份；默认不可导出是更安全的选择。
- 3 部署到指定服务器和指定账户。
- 4 用“测试”验证。
- 5 定期核对远端真实授权。
- 6 退役时先逐台远端撤销。
- 7 验证不能再登录。
- 8 最后删除设备本地密钥和无用记录。

3.2 公钥、私钥与导出

导出公钥

用途：交给服务器管理员手工加入授权列表。影响：只复制公开材料，不会泄露私钥。步骤：在密钥行点击“公钥”，核对密钥 ID 和类型后复制。验证：在接收处确认整行未换行、未截断。恢复：无需恢复；若发错对象，可重新生成独立密钥以便权限隔离。

导出私钥

用途：仅在明确需要迁移或离线恢复时使用。前置条件：生成密钥时已勾选“允许导出私钥”。影响：浏览器会收到完整私钥，剪贴板、下载目录、浏览器历史环境和备份系统都可能产生额外副本。步骤：只在可信电脑和隔离网络中点击“私钥”，立即保存到受控密钥库，随后清理临时副本。验证：确认保存的是预期密钥，并检查文件访问权限；不要把私钥粘贴到聊天、工单或日志中。恢复：私钥一旦发给错误对象不能“收回”。应按泄露事件处理：远端撤销、生成新密钥、重新部署、删除旧密钥。

3.3 “已部署主机”不是服务器事实源

这个列表只记录 TianshanOS 本地保存的主机配置。它不会持续读取服务器的 `authorized_keys`。

- “测试”成功：当前密钥现在能连接并执行测试命令。
- “测试”失败：原因可能是网络、服务器、账户、指纹或远端授权变化。
- “移除”：只删本地记录，远端公钥仍可能有效。
- “撤销”：尝试改远端授权；成功后才自动移除本地记录。

主机记录和已知主机指纹是两套独立数据。删除一边不会自动删除另一边。

3.4 SSH 主机指纹

主机指纹用于识别“连接的还是不是原来那台服务器”。当前页面保存的是主机公钥 SHA-256 摘要的 64 位十六进制文本。很多 OpenSSH 工具显示的是 `SHA256:base64`，两者不能直接按字符串比较；请让管理员以相同格式提供值。

首次连接

当前 WebUI 默认自动信任新主机，不会先让你确认指纹。完成首次部署后：

- 1 在“已知主机指纹”点击“查看”。
- 2 通过服务器控制台、资产系统或另一条可信渠道取得同一格式的指纹。
- 3 对比完整 64 位值，不要只比页面表格中的前 32 位摘要。
- 4 不一致时立即撤销可能已部署的公钥，并隔离调查。

服务器指纹变化

变化可能来自服务器重装、SSH 主机密钥轮换、IP 重新分配，也可能是中间人攻击。

- 1 停止重试，不要直接删除旧指纹。
- 2 从服务器控制台或管理员取得新的完整指纹和变更原因。
- 3 同时核对 IP、端口、资产编号和维护记录。
- 4 确认无误后，删除旧指纹记录。
- 5 在可信网络重新连接；当前实现会自动信任新指纹。
- 6 再次查看并比对已保存的新指纹。

代码中虽然存在一个详细的不匹配弹窗，但当前安全页调用链没有实际打开它。实际使用中可能只看到通用连接失败，请不要等待旧指南所描述的“更新主机密钥”确认窗口。

指纹记录的存储风险

记录保存在 NVS，并同步到 SD 卡的明文 JSON 文件。启动时，如果 SD 卡目录中有指纹配置，系统会清空 NVS 中的对应记录并以 SD 卡为准。SD 文件没有签名保护，所以 SD 卡必须按信任数据管理；不能把“记录存在”当成不可篡改证明。

3.5 导入和导出 SSH 主机配置

这是专用于“已部署主机”记录的 `.tscfg` 流程，与通用 Config Pack 的“应用配置”不同。

导出主机配置

谁可以操作：只有 Developer 设备。页面可能在普通设备也显示“导出”，但后端会拒绝。影响：生成包含主机地址、端口、用户名、认证类型和密钥 ID 的加密包；不包含 SSH 密码，也不包含对应私钥。步骤：Developer 设备点击主机行“导出”；要给另一设备使用时粘贴目标设备证书，否则会按界面提示使用本机目标。验证：确认下载了 `.tscfg`，并通过可信渠道核对目标设备证书指纹。恢复：导出不改变主机记录；错误目标生成的包应删除并重新导出。

导入主机配置

前置条件：包必须为本设备加密，且 SD 卡可写；接收设备还必须拥有包中引用的密钥 ID，否则记录加载后也无法连接。影响：确认导入只把 `.tscfg` 保存到 SD 卡；重启后才尝试加载主机记录。步骤：点击“导入主机配置”，选文件，阅读预览；如果同名记录存在，只有明确需要替换时才勾选覆盖；确认后按提示重启。成功后验证：重启后确认列表出现预期地址、用户、端口和密钥 ID，再点击“测试”。安全提醒：预览中的“签名通过”既不证明签名者可信，也不证明包是为本设备生成的。接收设备匹配要到重启后加载/解密时才会检查。恢复：使用“移除”删除错误的本地记录，并删除 SD 卡中对应包；这不会改变远端授权。

4. HTTPS 与 mTLS

4.1 先分清三种身份

- 1 设备私钥 + 设备证书：让 443 服务向客户端证明设备身份。
- 2 客户端证书：由连接设备的电脑、服务或人员持有，用于向 TianshanOS 证明客户端身份。
- 3 设备中安装的 CA 链：443 服务用它验证客户端证书。它不会自动让你的浏览器信任设备证书。

当前完整 WebUI 仍在 HTTP 80 端口。443 服务目前只提供健康、身份和权限测试接口。因此完成本节不等于可以通过 HTTPS 使用完整 WebUI。

4.2 规划证书名称和用途

联系 CA 管理员前先确定：

- 用户实际用 IP 还是 DNS 名访问；
- 证书 SAN 需要哪些 IP/DNS；
- 证书 EKU 是否包含服务器认证；
- 客户端证书的 EKU、签发 CA 和角色映射；
- 设备证书和 CA 链的更新、吊销及应急恢复方式。

当前自定义 CSR 表单只有 CN、O、OU，不生成 SAN。全部留空走默认 CSR 时，CN 固定为 `TIANSHAN-DEVICE-001`，只会在能够取得当前 IP 时加入一个 IP SAN，不含 DNS SAN。若这不符合实际访问地址，请不要直接使用页面 CSR 完成生产签发；应由 PKI 管理员在受控流程中生成满足要求的 CSR/证书方案。

4.3 生成 HTTPS 密钥

页面向谁显示：admin 和 root 都可看到证书管理操作。当前通用 API 未强制执行这一角色边界，所以必须依赖网络隔离。会改变什么：生成独立的 ECDSA P-256 私钥。已有密钥时继续会覆盖它。步骤：在“HTTPS 证书”点击“生成密钥”；如出现已有密钥警告，先停止并确认旧证书、Config Pack 和恢复方案，再决定是否覆盖。成功后应该看到：状态变为“密钥已生成，等待 CSR”，密钥表出现 `https` 条目。验证：刷新页面，确认仍显示私钥存在；私钥不可从此界面导出。恢复：没有旧私钥备份时，覆盖不可逆；需要重新签发证书并重新制作依赖旧证书的配置包。

4.4 生成并签发 CSR

会改变什么：生成申请文本，不会安装证书，也不会泄露私钥。步骤：点击“生成 CSR”，填写 CN/O/OU 或全部留空使用默认路径，生成后复制完整 PEM 给 CA 管理员。验证：让 CA 管理员解析 CSR，确认公钥、主体和 SAN。尤其要明确：自定义字段路径当前没有 SAN。失败处理：没有设备私钥时先生成密钥；若 CA 要求 DNS/IP SAN，停止使用此表单并由 PKI 管理员处理。恢复：CSR 可重新生成；重新生成密钥后，旧 CSR 和旧签发证书都会失效。

4.5 安装设备证书

前置条件：PEM 证书必须与设备当前私钥匹配。会改变什么：把设备证书保存到证书存储。步骤：点击“安装证书”，粘贴完整 PEM，提交。成功提示实际表示：当前实现确认 PEM 能解析，且证书公钥与当前私钥匹配。它没有完成签发链、SAN、EKU、当前有效期或主体策略的完整校验。验证：查看证书，核对主体、签发者、有效期；再由目标客户端实际验证证书链、访问地址 SAN 和服务器认证 EKU。必要时重启设备后测试 443。失败处理：格式错误时检查 PEM 边界和换行；密钥不匹配时找回与当前 CSR 对应的证书，不要盲目覆盖密钥。恢复：安装错误证书时可安装与当前私钥匹配的正确证书；删除全部 PKI 会同时删除私钥和 CA 链，风险更大。

4.6 安装客户端 CA 链并验证 mTLS

适用场景：要求访问 443 服务的客户端出示证书。会改变什么：把一组 CA 证书保存为客户端证书验证信任链。步骤：点击“安装 CA 链”，按界面要求粘贴一个或多个 PEM 证书并安装。验证：重启或重启 443 服务后，用以下两类客户端分别测试：一张由该 CA 签发、用途和角色正确的客户端证书；一张不受信任或无证书的客户端。前者应能访问其角色允许的测试端点，后者应失败。当前限制：静态代码没有显示证书安装后自动重载正在运行的 443 服务，因此是否需要重启必须通过真机验证。恢复：保留设备的本地管理入口。CA 配错导致 443 不可用时，从 HTTP 管理网重新安装正确 CA 或删除并重建 PKI。

4.7 删除全部 PKI 凭证

适用场景：私钥泄露、设备退役、完整重建 PKI。影响：同时删除 HTTPS 私钥、设备证书和客户端 CA 链，界面标记为不可撤销；依赖旧设备私钥解密的 Config Pack 也可能永久不可用。步骤：先确认 HTTP 管理入口可用、备份必要的公开证书和外部恢复材料，再点击“删除”并确认。验证：刷新后状态应为未初始化；重启后确认 443 不再使用旧证书。恢复：重新生成密钥、重新签发和安装设备证书、重新安装客户端 CA 链，并重新执行 mTLS 验收。

5. Config Pack

5.1 它的信任关系

一个包涉及四个动作：

- 1 导出设备把配置内容加密给目标设备证书。
- 2 只有持有对应设备私钥的目标设备能解密。
- 3 导出设备用自己的设备私钥签名包内密文。
- 4 接收设备用包内附带的签名者证书验证签名。

第四步目前只证明“签名与包里附带的证书匹配”。当前实现没有完成签名者证书链信任验证。包内“官方”字段可由包提供，证书 OU 含 Developer 也会被标记为官方。因此：

“签名有效”不等于“签名者可信”，“官方”也不能作为可信身份结论。

导入前必须通过设备资产系统、线下交接或管理员认可的其他渠道核对签名者证书或指纹。

5.2 当前哪些功能可用

操作	当前实际结果	是否建议用于生产
导出设备证书	显示/复制设备公开证书，供发送方加密给本设备	可用，但需可信渠道核对指纹
验证粘贴的包	验证包结构和自带证书对应的签名	只能做完整信任检查的一部分
安全页“导入配置包”	前端发送包内容，后端当前只接受设备文件路径	当前不可用
配置包列表“导入”	只验证设备上已有文件，不复制、不解密、不应用	不代表导入或生效
“应用”	解密并列出顶层模块名，但当前没有调用各模块配置写入逻辑，仍可能显示成功	当前不能作为配置生效流程
Developer 导出配置包	加密并签名 JSON，可下载并尝试保存到 SD 卡	可生成包，但接收端通用应用尚未闭环

5.3 导出设备证书

页面向谁显示：admin 和 root 都可看到导出口。这是前端可见性，不代表后端已执行角色鉴权。影响：只导出公开证书，不导出私钥。步骤：点击“导出设备证书”，复制 PEM，并同时记录显示的证书指纹。验证：接收方通过另一条可信渠道核对指纹。不要只凭邮件或聊天中同一条消息同时接收证书和指纹。恢复：发错公开证书通常不泄露私钥，但会造成包加密给错误设备；删除错误包并重新制作。

5.4 验证收到的配置包

页面向谁显示：admin 和 root 都可看到验证入口。这是前端可见性，不代表后端已执行角色鉴权。会改变什么：“验证”本身不应用配置。步骤：打开“导入配置包”，选择或粘贴 .tscfg，点击“验证”；记录签名者 CN、OU、签名时间和“官方”显示。这个“验证”不检查包内接收设备指纹是否等于本机。验证之后还必须做什么：从可信资产记录取得预期签名者证书指纹并核对；确认目标设备证书未更换；由人工审查包的来源、用途、变更范围和恢复方案。停止条件：签名者未知、来源无法核对、目标设备不符、包用途不清或要求你忽略警告时，停止操作。

5.5 不要用当前通用“应用”判断配置已生效

当前通用 Config Pack 流程存在两个独立断点：

- 1 安全页上传/粘贴后的“导入”与后端参数不匹配，无法完成该流程。
- 2 即使包已在设备路径中并进入“应用”，实现也只枚举模块名，没有真正写入模块配置，却可能返回成功。

因此当前版本中：

- 不要把“已导入”“验证成功”“应用成功”或“已应用模块”当成配置变化证据。
- 不要用 Config Pack 承担生产批量配置、灾难恢复或合规变更。
- SSH 主机专用的 `.tscfg` 导入是另一条独立流程，只保存主机记录并在重启后加载，也不携带密钥私钥或远端授权。

5.6 Developer 导出配置包

谁可以操作：后端只允许设备证书标记为 Developer 的设备完成导出；页面本身对 admin 和 root 都显示入口。当前 `config.admin` 只是 API 注册元数据，不能视为已执行的账号权限校验。前置条件：SD 卡中存在有效 JSON 配置文件；已取得并核对目标设备证书。影响：把选中的 JSON 内容合并、加密给目标证书并由当前设备签名；同时尝试保存到 `/sdcard/output_config/`，并在浏览器提供复制/下载。步骤：点击“导出配置包”，选择一个或多个 JSON 文件，填写名称/说明，粘贴目标设备证书，生成后下载。验证：分别确认浏览器下载文件和设备保存路径；保存 SD 失败时仍可能返回包内容。由接收方验证包和目标指纹，但不要宣称它能在当前实现中通用应用。恢复：导出不会改变源配置；错误包应删除并重新生成。目标证书一旦更换，旧包可能无法解密。

6. 安全事件与恢复

6.1 SSH 私钥疑似泄露

- 1 立即限制设备和日志访问；当前 SSH INFO 日志可能包含私钥开头片段。
- 2 从可信管理入口逐台服务器删除该公钥，不要依赖本地列表覆盖所有服务器。
- 3 检查并清理远端 `authorized_keys.bak` 和其他备份副本。
- 4 验证旧密钥不能登录。
- 5 生成新的 RSA 密钥并重新部署。
- 6 删除旧设备密钥和所有导出的私钥副本。
- 7 审计泄露期间的登录日志。

6.2 服务器重装或指纹变化

停止连接 → 从控制台取得新指纹 → 核对变更记录和资产身份 → 删除旧记录 → 在可信网络重连 → 再次核对新记录。任何一步无法证明服务器身份时都不要继续。

6.3 证书过期或 HTTPS 私钥泄露

- 仅证书即将过期：使用当前私钥生成合适 CSR，签发并安装新证书，再做客户端验证。
- 私钥泄露：不要复用旧私钥。先确保 HTTP 管理入口可用，删除/替换整套 PKI，重新签发设备证书和客户端 CA 配置，并废弃依赖旧私钥的配置包。

6.4 远端撤销与本地记录不一致

- 远端已删、本地仍有：验证旧密钥不能登录，然后“移除”本地记录。
- 本地已删、远端仍有：从服务器控制台或另一管理员账户手工删除公钥；本地记录删除不会帮你完成这一步。
- 不确定：以远端 `authorized_keys` 和实际登录测试为准，不以页面列表为准。

6.5 删除凭证前的恢复入口

删除 SSH 密钥前，确认有服务器控制台或另一管理员密钥；删除 PKI 前，确认 HTTP 管理网仍可访问；更换设备证书前，确认需要保留的 Config Pack 已有替代方案。没有恢复入口就停止删除。

7. 故障排查

你看到的现象	先检查什么	下一步	何时停止
看不到“账号安全”	当前是否以 root 登录	需要改 root/admin 密码时改用 root	不要把 admin 权限误认为故障
登录提示锁定	是否连续输错 5 次	等待约 5 分钟；root 可重置 admin	无法确认账号或设备身份时停止猜密码
“生成密钥”失败	密钥 ID 是否重复、SSH 密钥是否已满 8 个	按撤销顺序清理不用的密钥	需要删除仍在使用的密钥时停止
ECDSA 密钥部署/测试失败	是否把 ECDSA 用作 SSH 密钥	新建 RSA 密钥并部署	不要反复修改服务器策略来迎合错误类型
部署成功但测试失败	地址、用户、端口、远端权限和算法；是否产生重复行	从另一入口检查 <code>authorized_keys</code>	指纹或服务器身份不确定时停止
主机指纹错误或突然变化	控制台指纹、维护记录、IP 是否换机	按指纹变化流程处理	无法从可信渠道核实时立即停止
点击“移除”后仍能登录	“移除”只删本地记录	在服务器端撤销公钥	没有其他管理入口时不要冒险改授权
撤销提示未找到	远端是否已手工删除、是否选对密钥/账户	确认远端不存在后再移除本地记录	无法查看远端时不要宣称已撤销
普通设备导出主机配置失败	设备是否为 Developer	普通设备当前不支持该导出	不要通过修改证书 OU 冒充 Developer
CSR 签发后客户端仍报名称不匹配	实际访问地址是否在 SAN	让 PKI 管理员重新生成合适证书	不要仅修改 CN 规避 SAN 校验
安装证书成功但 443 不可用	是否同时有私钥、设备证书、客户端 CA；服务是否需重启	重启后用合格/不合格客户端证书各测试一次	没有 HTTP 恢复入口时停止删除 PKI
浏览器仍不信任设备证书	浏览器侧是否信任服务器 CA，SAN/EKU/链是否正确	在客户端正确配置信任链	不要把设备里的客户端 CA 当浏览器信任库
Config Pack “导入”失败	是否使用了安全页粘贴导入	当前流程参数不匹配，不再重试	不要转而依赖“应用成功”提示
Config Pack 显示“应用成功”但配置没变	当前应用逻辑没有写模块配置	回到各功能页面按受支持方式配置	不要用该提示做生产验收

8. 当前必须接受的安全限制

在产品实现改变并完成重新核验之前，请以以下边界做风险判断：

- 1 完整 WebUI 通过 HTTP 工作，敏感内容可能明文经过网络。
- 2 SSH 密码认证发生在主机指纹验证之前；新主机默认自动信任。
- 3 已知主机 SD 卡文件是未签名明文，并在启动加载时优先于 NVS。
- 4 当前构建未启用 NVS Encryption、Flash Encryption 和 Secure Boot；不要宣称私钥已获得这些保护。
- 5 “隐藏密钥 ID” 目前不构成保密或权限控制。
- 6 SSH 日志可能包含私钥开头片段。
- 7 通用 Web API 当前没有执行统一的登录和权限校验；`requires_auth / permission` 仅登记未执行。证书“安装成功”也不是完整 PKI 验证。
- 8 443 mTLS 服务不是完整 WebUI，安装到设备的 CA 用于验证客户端证书。
- 9 Config Pack 没有完成签名者证书链信任验证，“官方”标记不可信。
- 10 通用 Config Pack 导入与应用当前未闭环，不能用来证明配置已生效。

如果你的使用场景无法接受其中任何一项，请停止把设备放入该信任边界，并由安全负责人决定网络隔离、外部补偿控制或产品修复方案。